04/04/26

Report:
SOC Lab - SIEM & Active Directory

A cura di Alessandro Criscuoli

EPICODE

Indice

Introduzione 2

Componenti e Ruoli dell'Infrastruttura 2

High Level Design e Static Route 3

Firewall pfSense: Configurazione delle Rules 4

Domain Controller 4

Ubuntu Server: Provisioning 5

Sincronizzazione Temporale (NTP) e Domain Join 6

Windows Client: Provisioning e Network Setup 7

Splunk SIEM: Installazione e Setup Universal Forwarder 7

Active Directory: Organizational Units, Users e Groups 8

Group Policy: Configurazione Audit Filtering Platform 9

Group Policy Management Editor e Splunk Monitoring 10

Threat Detection: WebGUI Splunk e Nmap Aggressive Scan 11

Analisi dei Log: Estrazione traffico Network (Event ID 5156/5157) 12

AI Support: Query Avanzate e Nuova GPO Domain Controller 13

Verifica Audit: Creazione Utenza (Event ID 4720) 14

Conclusione 15

Introduzione

Il presente report descrive l'architettura, la preparazione e la configurazione completa del laboratorio SOC (Security Operations Center) basato su virtualizzazione locale, per poi passare ad una simulazione di evento non autorizzato sull'infrastruttura e di come il SIEM ne evidenzia traccia tramite Logs. Si mostrerà inoltre il Monitoring AD del SIEM a fronte di azioni provenienti dal Domain Controller.

Componenti e Ruoli dell'Infrastruttura

● *pfSense (Perimeter Firewall & Gateway):* Gestisce la Network Segmentation e le policy di Traffic Filtering. Funge da punto di demarcazione tra WAN e LAN, controllando il routing e la sicurezza perimetrale.

● *Ubuntu 24.04 (SIEM - Splunk Enterprise):* Nodo centrale per la Log Ingestion e la Event Correlation. Analizza i flussi di dati provenienti dai forwarder per attività di Threat Detection e Incident Response.

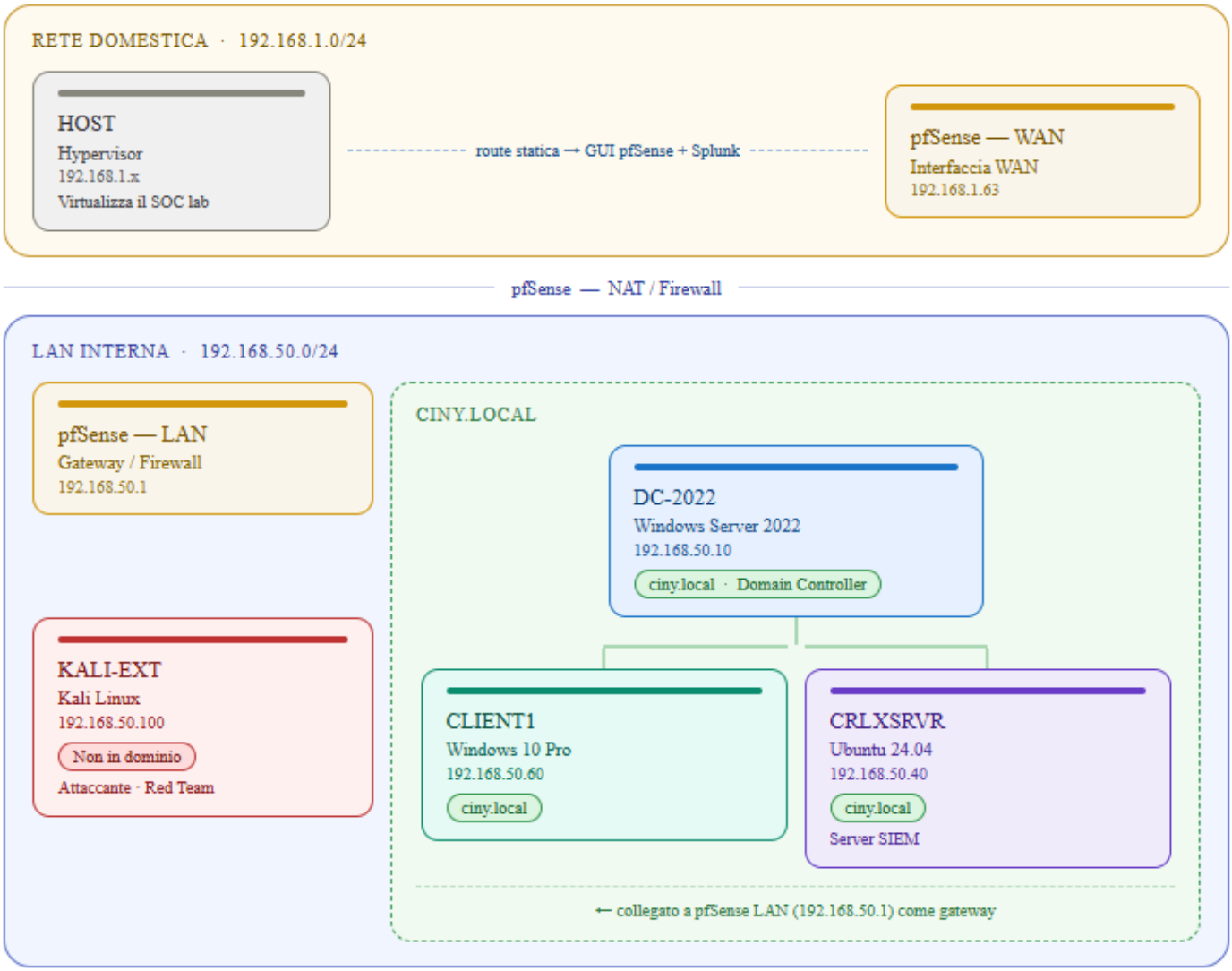
● *Windows Server 2022 (Domain Controller):* Autorità centrale del dominio. Gestisce l'autenticazione degli utenti attraverso il protocollo Kerberos e supervisiona l'intero sistema di gestione delle identità e degli accessi, garantendo che ogni utente sia correttamente identificato e possa raggiungere solo le risorse per cui ha un'autorizzazione specifica. Amministra inoltre la condivisione di file e cartelle all'interno della rete, definendo le liste di controllo degli accessi per proteggere i dati e distribuendo i Criteri di Gruppo per imporre configurazioni di sicurezza uniformi su tutti i dispositivi.

● *Windows 10 Pro (Endpoint / Workstation):* Terminale utente configurato come Domain Member. Rappresenta l'host bersaglio per test di Exploitation e monitoraggio della sicurezza a livello Endpoint.

● *Kali Linux (Attacker Host):* Piattaforma dedicata all'Adversary Simulation. Utilizzata per attività di Red Teaming, tra cui Vulnerability Scanning (Nmap) e simulazione di vettori di attacco verso la LAN.

Host	S.O.	IP Locale	Ruolo	Dominio
pfSense	FreeBSD (custom)	192.168.1.63 192.168.50.1	Gateway / Firewall	—
DC-2022	Windows Server 2022	192.168.50.10	Domain Controller	ciny.local
CLIENT1	Windows 10 Pro	192.168.50.60	Workstation utente	ciny.local
SIEM-SRV	Ubuntu Server 24.04	192.168.50.40	Splunk Enterprise	ciny.local
KALI-EXT	Kali Linux	192.168.50.100	Attaccante (Red Team)	Non in dominio
HOST	Hypervisor	192.168.1.x	Macchina fisica host	—

IT Infrastructure



Static Route

È stata impostata sulla macchina host una Static Route permanente che instrada tutto il traffico destinato alla subnet 192.168.50.0/24 verso il Gateway 192.168.1.63, assegnandogli la massima priorità tramite una Metric pari a 1.

```
===========================================================================
Route permanenti:
   Indirizzo rete            Mask   Indir. gateway Metrica
         0.0.0.0          0.0.0.0    192.168.1.254  Predefinito
     192.168.50.0    255.255.255.0     192.168.1.63       1
===========================================================================
```

Firewall Pfsense

Le Firewall Rules sull'interfaccia WAN consentono selettivamente il traffico TCP proveniente dall'host (192.168.1.60) verso i servizi di gestione interna, garantendo l'accesso amministrativo via SSH (port 22), l'amministrazione web di pfSense (port 443) e la WebGUI di Splunk (port 8000).

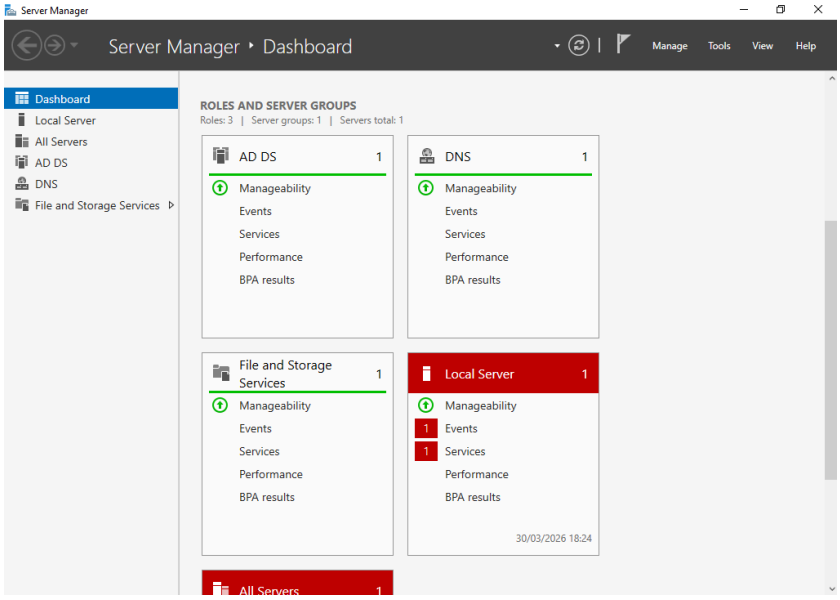
Floating | WAN | LAN | LAN2

Rules (Drag to Change Order)

States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
0/4 KiB	*	Reserved Not assigned by IANA	*	*	*	*	*		Block bogon networks	
0/716 KiB	IPv4 TCP	192.168.1.60	*	LAN subnets	22 (SSH)	*	none		Accesso a LAN da macchina Host su private network (192.168.1.0)	
0/0 B	IPv4 TCP	192.168.1.60	*	WAN address	443 (HTTPS)	*	none		Accesso Pfsense WebGUI da Host	
0/1.79 MiB	IPv4 TCP	192.168.1.60	*	192.168.50.40	8000	*	none		Accesso SPLUNK WebGUI da Host	

Domain Controller

Il processo di configurazione è iniziato con la promozione del server al ruolo **Domain Controller** tramite l'interfaccia del **Server Manager**. Una volta completata l'aggiunta dei componenti necessari (**Active Directory**) è stata selezionata l'opzione per la creazione di una **nuova foresta**, definendo **`ciny.local`** come nome del dominio radice. Dopo il riavvio finale, il server ha assunto la piena gestione delle identità, dei criteri di sicurezza e dell'autenticazione centralizzata per l'intera infrastruttura.



Ubuntu Server

Si procede con il provisioning della Ubuntu 24.04.4 LTS: Con la modifica del file di configurazione */etc/netplan/50-cloud-init.yaml* si ha configurato il server per operare con IP statico e integrato nel dominio.

```
  GNU nano 7.2                                  /etc/netplan/50-cloud-init.yaml
network:
  version: 2
  renderer: networkd
  ethernets:
    enp0s3:
      dhcp4: no
      addresses:
       - 192.168.50.40/24
      routes:
       - to: default
         via: 192.168.50.1
      nameservers:
       search:
        - ciny.local
       addresses:
        - 192.168.50.10
```

Si ha proseguito con l'aggiornamento dei repository di sistema e installazione dei packages necessari per abilitare l'integrazione del server Linux nel dominio Active Directory e la gestione della authentication centralizzata tramite protocollo kerberos.

```
sysadmin@crlxsrvr:~$ sudo apt update && sudo apt install realmd sssd sssd-tools adcli krb5-user
 packagekit samba-common-bin -y
[sudo] password for sysadmin:
```

Prima di procedere con l'unione effettiva al dominio, è stata eseguita una fase di Discovery utilizzando il comando *realm discover ciny.local,* operazione fondamentale per validare la raggiungibilità del Domain Controller e la corretta configurazione dei servizi di rete.

```
sysadmin@crlxsrvr:~$ realm discover ciny.local
ciny.local
  type: kerberos
  realm-name: CINY.LOCAL
  domain-name: ciny.local
  configured: no
  server-software: active-directory
  client-software: sssd
  required-package: sssd-tools
  required-package: sssd
  required-package: libnss-sss
  required-package: libpam-sss
  required-package: adcli
  required-package: samba-common-bin
```

La configurazione di */etc/systemd/timesyncd.conf* è un passaggio critico per garantire la coerenza temporale. In un ambiente basato su Active Directory, la sincronizzazione precisa dell'orologio tra il server Linux e il Domain Controller è una necessità tecnica per il corretto funzionamento dei protocolli di sicurezza.

```
sysadmin@crlxsrvr:~$ sudo nano /etc/systemd/timesyncd.conf
[sudo] password for sysadmin:
```

L'editing di questo file permette di definire i server per il **Network Time Protocol**, in modo da garantire l'autenticazione Kerberos, la correlazione dei log nel SIEM e l'integrità del sistema.
Il comando di seguito conferma che il server ha stabilito con successo una connessione con il server NTP di riferimento (il Domain Controller) e che lo scarto temporale è nullo.

```
sysadmin@crlxsrvr:~$ timedatectl status
               Local time: Thu 2026-03-26 22:59:07 CET
           Universal time: Thu 2026-03-26 21:59:07 UTC
                 RTC time: Thu 2026-03-26 21:53:25
                Time zone: Europe/Rome (CET, +0100)
System clock synchronized: yes
              NTP service: active
          RTC in local TZ: no
```

Il comando *realm* rappresenta il momento in cui la macchina Linux viene ufficialmente registrata come oggetto all'interno della foresta di dominio ciny.local.
-U Administrator@CINY.LOCAL specifica l'utente amministrativo con i privilegi necessari per autorizzare la creazione di una workstation all'interno dell'Active Directory.

```
sysadmin@crlxsrvr:~$ sudo realm join -v -U Administrator@CINY.LOCAL ciny.local
 * Resolving: _ldap._tcp.ciny.local
 * Performing LDAP DSE lookup on: 192.168.50.10
 * Successfully discovered: ciny.local
Password for Administrator@CINY.LOCAL:
```

L'output finale dell'utility `realm` conferma il successo dell'operazione di Domain Join e l'automatizzazione dei processi di configurazione della sicurezza locale sul server Ubuntu. Questa fase sancisce la transizione dell'host da dispositivo isolato a membro fidato dell'infrastruttura Active Directory.

```
* Checking RestrictedKrbHost/CRLXSRVR
*    Added RestrictedKrbHost/CRLXSRVR
* Checking host/CRLXSRVR
*    Added host/CRLXSRVR
* Discovered which keytab salt to use
* Added the entries to the keytab: CRLXSRVR$@CINY.LOCAL: FILE:/etc/krb5.keytab
* Added the entries to the keytab: host/CRLXSRVR@CINY.LOCAL: FILE:/etc/krb5.keytab
* Added the entries to the keytab: RestrictedKrbHost/CRLXSRVR@CINY.LOCAL: FILE:/etc/krb5.keytab
* /usr/sbin/update-rc.d sssd enable
* /usr/sbin/service sssd restart
* Successfully enrolled machine in realm
```

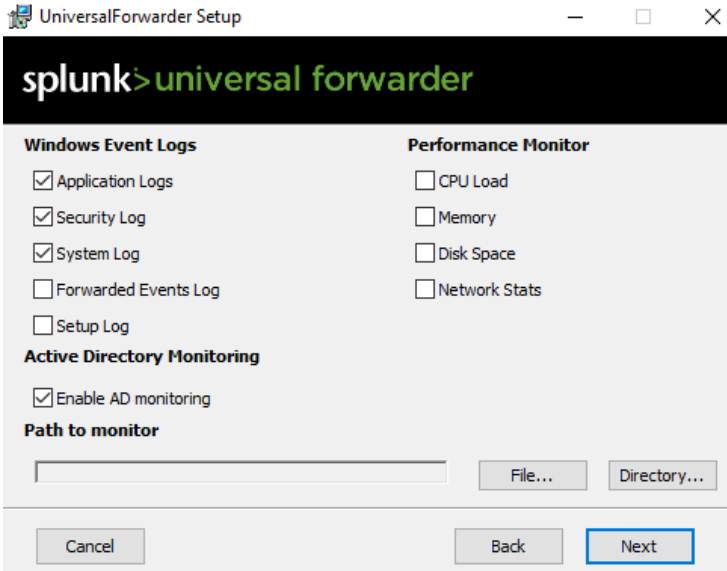
Windows Client

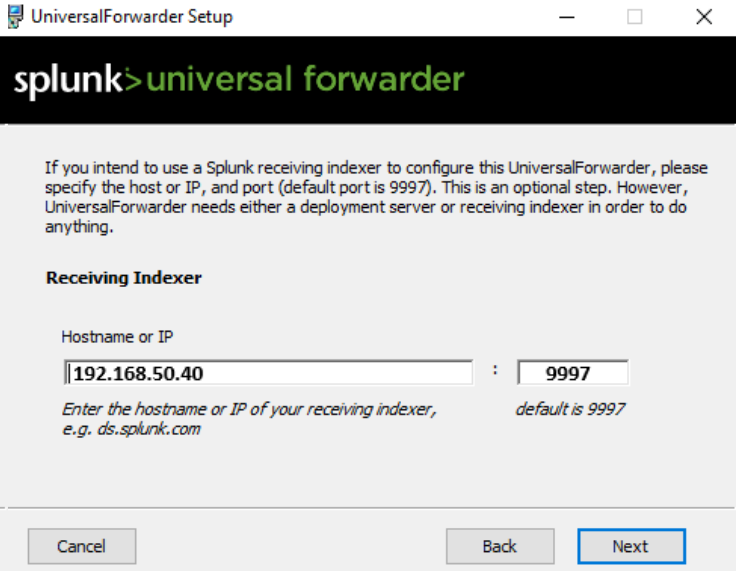
Il provisioning del client Windows 10 Pro è iniziato con la configurazione dei parametri di rete, procedendo alla scelta di un IP statico. Un passaggio determinante è stato il puntamento del DNS verso il Domain Controller, operazione necessaria per permettere al sistema di individuare correttamente le risorse della foresta ciny.local. Una volta stabilita la risoluzione dei nomi, è stata eseguita la procedura di unione al dominio, validata attraverso le credenziali amministrative per permettere la creazione della workstation nel Active Directory.

```
C:\Users\michele.stella>net config workstation
Computer name                        \\CLIENT1
Full Computer name                   CLIENT1.ciny.local
User name                            michele.stella
```

Splunk SIEM

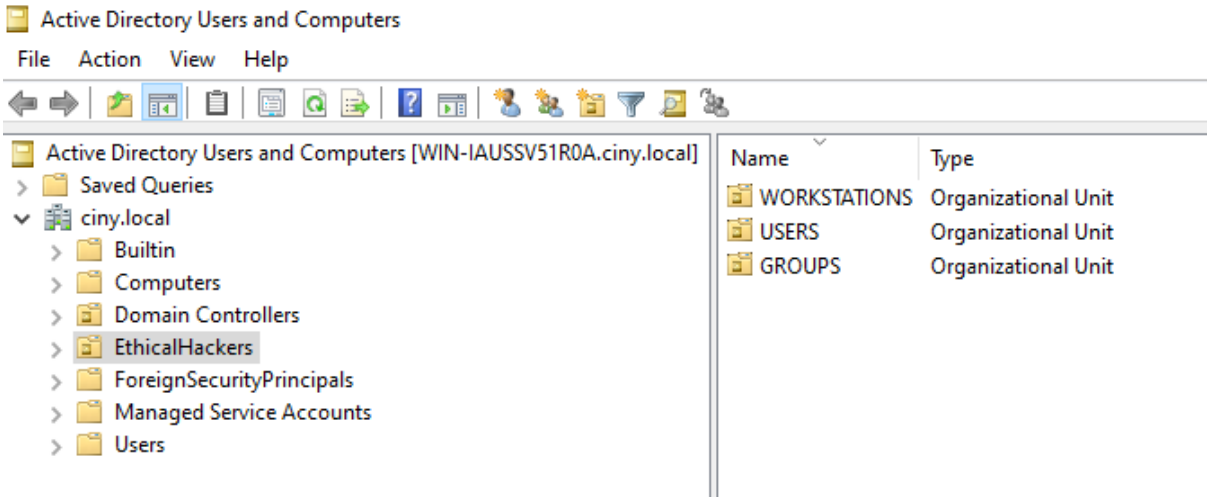
Una volta preparato l'ambiente Ubuntu, si ha installato il **SIEM Splunk Enterprise**. Per garantire la persistence, si ha configurato il boot-start tramite systemd. Al primo avvio, dopo l'accettazione della License Agreement e la creazione dell'account amministrativo, il SIEM è pronto per essere configurato come ricevitore logs, entrando nella web gui, su impostazioni è stata settata la porta 9997 per la ricezione dei log provenienti dai dispositivi da monitorare. Si ha quindi installato Splunk Universal Forwarder sul client windows 10 e sul DC, all'avvio viene richiesto quali logs includere, sono stati selezionate le flag per i logs di Security, System, Application e di Active Directory per poi indicare IP e porta del SIEM.





Active Directory

Si ha organizzato una struttura logica al dominio ciny.local iniziando con la creazione delle **Organizational Units**, creando dei contenitori dedicati per separare nettamente le diverse tipologie di risorse (workstations, users e groups) e permettere in futuro l'applicazione mirata dei criteri di sicurezza. Proseguendo, si ha popolato il database creando nuovi user e raggruppandoli in un gruppo specifico; questa configurazione è essenziale per implementare un modello di **Access Control** coerente, dove i permessi non vengono assegnati al singolo, ma in base al ruolo ricoperto.



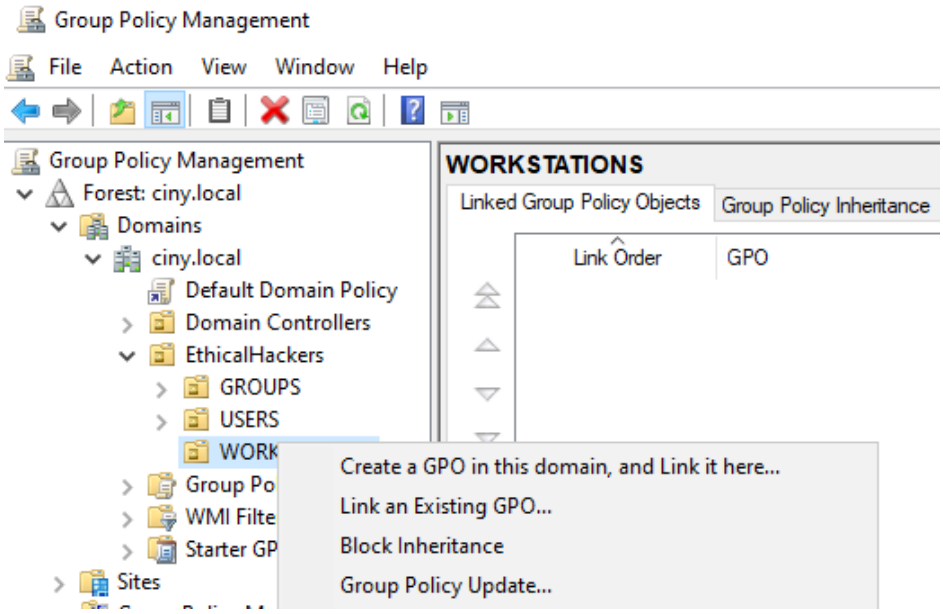
Name	Type	Description
CRLXSRVR	Computer	Linux host di Splunk
CLIENT1	Computer	Windows 10 Pro di Michele Stella

Name	Type	Description
Michele Stella	User	Utente di Ciny
Edoardo Epicode	User	Amministratore Epicode
Alessandro Criscuoli	User	Primo utente di Ciny
Administrator	User	Domain Administrator

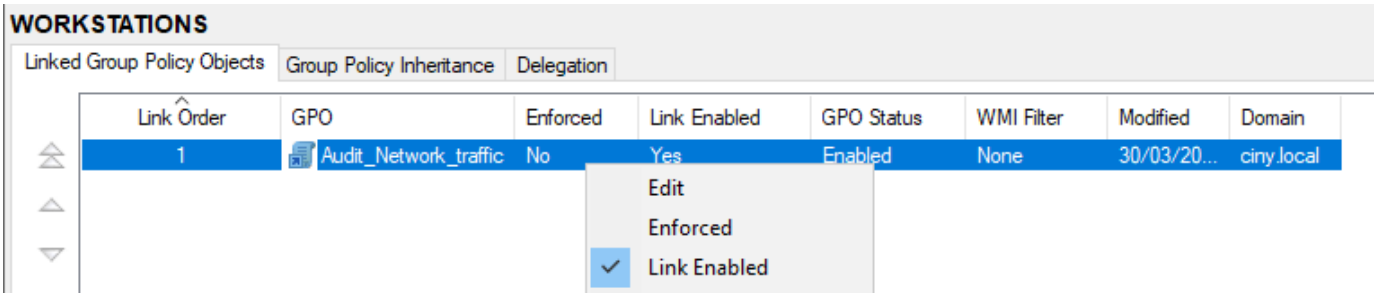
Name	Type	Description
Test	Security Group - Domain Local	Primo gruppo di Ciny

Group Policy

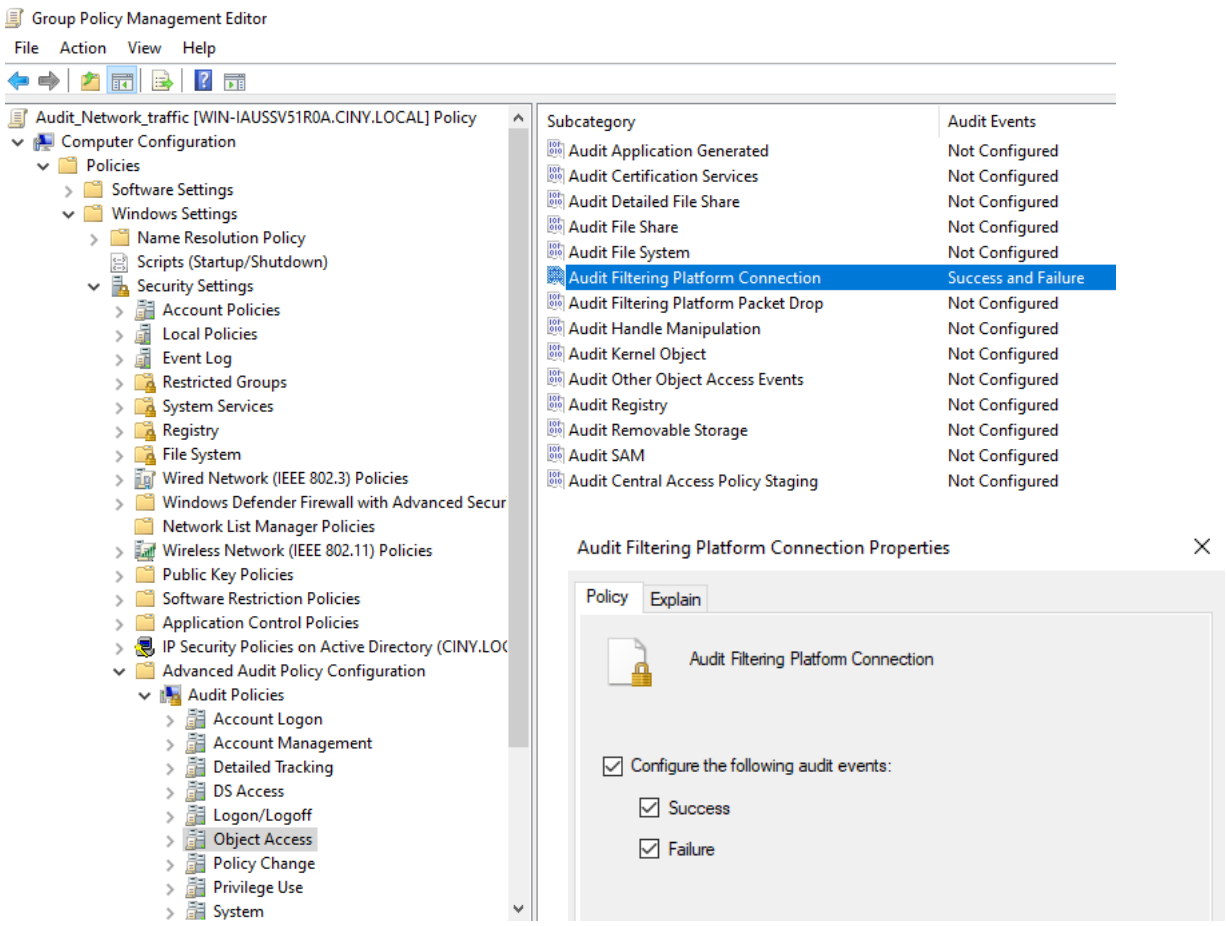
Per permettere il tracciamento di logs a **livello network** si ha creato una Group Policy, dal Domain Controller, che impone ai computer di annotare ogni singolo tentativo di connessione che ricevono, sia quelli autorizzati che quelli respinti dal firewall.
Dal **Group Policy Management,** selezionando la Organization Unit "WORKSTATIONS", creato precedentemente su AD, si ha selezionato "Create a GPO in this domain".



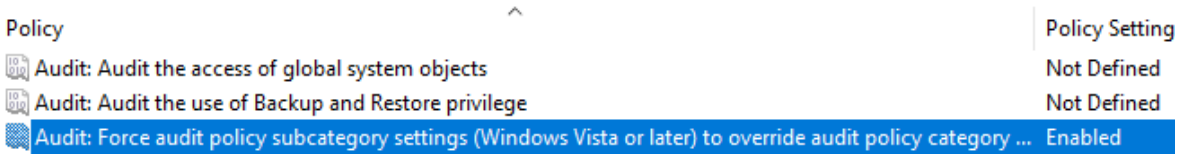
Si creerà quindi un nuovo **Object**, è stato chiamato "Audit_Network_Traffic", facendo click destro su di esso si andrà a modificare la Policy.



Nell'editor, entrando su *Computer Configuration > Policies > Windows Settings > Security Settings > Advanced Audit Policy Configuration > Audit Policies > Object Access* si ha selezionato la subcategory **Audit Filtering Platform Connection** attivando gli eventi di controllo per "success" e "failure".



Per forzare la sync della Policy sul dominio si è andati con l'editor policy sotto *Security Settings* > *Local Policies* > *Security Options* per abilitare l'override delle policy:



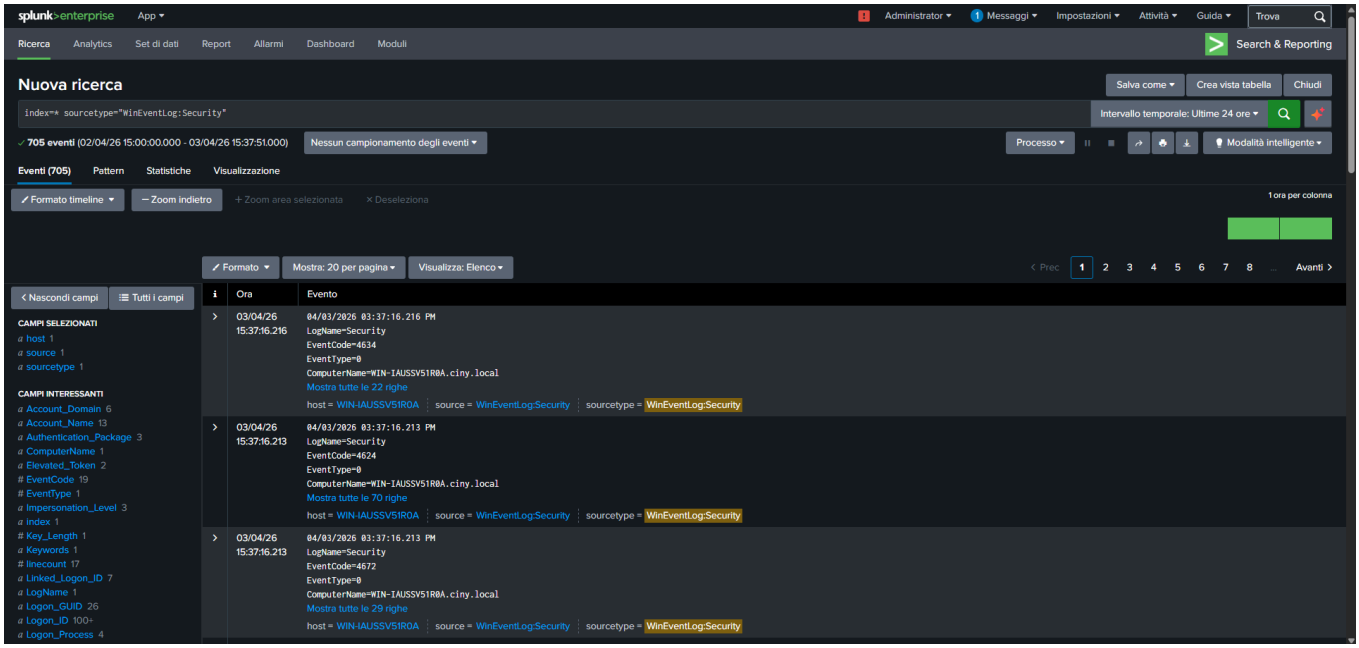
Splunk Monitoring

Una volta completata la configurazione lato Domain Controller e verificato l'update delle policy lato client, si può procedere verificando lo stato del servizio Splunk, risultando attivo si ha raggiunto le webGUI del SIEM all'indirizzo *http://192.168.50.40:8000*

```
sysadmin@crlxsrvr:~$ systemctl status Splunkd
● Splunkd.service - Systemd service file for Splunk, generated by 'splunk enable boot-start'
     Loaded: loaded (/etc/systemd/system/Splunkd.service; enabled; preset: enabled)
     Active: active (running) since Fri 2026-04-03 15:03:53 CEST; 5min ago
    Process: 699 ExecStartPost=/bin/bash -c chown -R root:root /sys/fs/cgroup/system.slice/Splunkd.service
```

Threat Detection

Il centro di raccolta dei dati grezzi trasformati in log più o meno comprensibili è la WebGUI di Splunk Enterprise, l'ambiente di lavoro principale è rappresentato dalla Search & Reporting, dove è presente una console intuitiva dove è possibile interrogare l'intero database dei log utilizzando il linguaggio **SPL** (Search Processing Language).



Appena visitata la webGUI già si possono vedere dei log estratti dai sistemi windows, quelli di interesse però si andranno a generare attraverso una scansione di rete che provocheranno lato firewall gli **Event ID 5156 e 5157** (connection allowed e blocked).
Entrando quindi sulla Kali Linux si ha iniziato una scansione aggressiva con Nmap, allo scopo di generare più "rumore" possibile.

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -A -T4 192.168.50.60
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 13:05 -0400
Stats: 0:00:01 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 0.50% done
Nmap scan report for 192.168.50.60
Host is up (0.00073s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT    STATE SERVICE VERSION
135/tcp open  msrpc   Microsoft Windows RPC
MAC Address: 08:00:27:D7:FE:77 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 10|11|2019 (92%)
OS CPE: cpe:/o:microsoft:windows_10 cpe:/o:microsoft:windows_11 cpe:/o:microsoft:windows_server_2019
Aggressive OS guesses: Microsoft Windows 10 1903 - 21H1 (92%), Microsoft Windows 10 1803 (91%), Microsoft
s 10 1909 - 2004 (85%), Windows Server 2019 (85%), Microsoft Windows 10 1809 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

TRACEROUTE
HOP RTT     ADDRESS
1   0.73 ms 192.168.50.60
```

Tramite la query SPL di seguito è stato possibile estrarre i log relativi al traffico di rete generato dalla scansione Nmap verso il client Windows con hostname "CLIENT1"

index= sourcetype="WinEventLog:Security" Source_Address="192.168.50.100"*

CONNECTION BLOCKED

Event ID 5157

Audit Failure

```
30/03/26
20:15:07.538
03/30/2026 08:15:07.538 PM
LogName=Security
EventCode=5157
EventType=0
ComputerName=CLIENT1.ciny.local
SourceName=Microsoft Windows security auditing.
Type=Information
RecordNumber=5667
Keywords=Audit Failure
TaskCategory=Filtering Platform Connection
OpCode=Info
Message=The Windows Filtering Platform has blocked a connection.

Application Information:
        Process ID:             4
        Application Name:       System

Network Information:
        Direction:              Inbound
        Source Address:         192.168.50.100
        Source Port:            9
        Destination Address:    192.168.50.60
        Destination Port:               8
        Protocol:               1

Filter Information:
        Filter Run-Time ID:     69914
        Layer Name:             Receive/Accept
        Layer Run-Time ID:      44
Comprimi
host = CLIENT1   source = WinEventLog:Security   sourcetype = WinEventLog:Security
```

CONNECTION ALLOWED

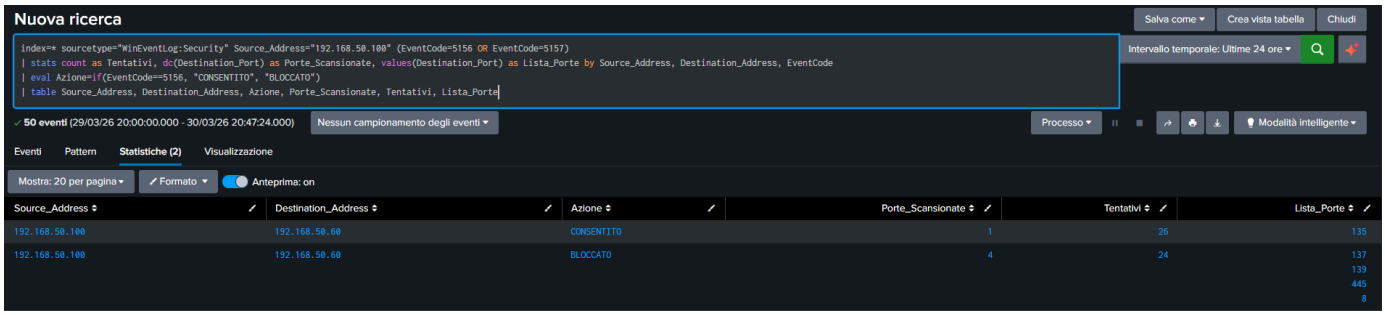
Event ID 5156

Audit Success

```
30/03/26
20:15:07.515
03/30/2026 08:15:07.515 PM
LogName=Security
EventCode=5156
EventType=0
ComputerName=CLIENT1.ciny.local
SourceName=Microsoft Windows security auditing.
Type=Information
RecordNumber=5666
Keywords=Audit Success
TaskCategory=Filtering Platform Connection
OpCode=Info
Message=The Windows Filtering Platform has permitted a connection.

Application Information:
        Process ID:             864
        Application Name:       \device\harddiskvolume2\windows\system32\svchost.exe

Network Information:
        Direction:              Inbound
        Source Address:         192.168.50.100
        Source Port:            36383
        Destination Address:    192.168.50.60
        Destination Port:               135
        Protocol:               6

Filter Information:
        Filter Run-Time ID:     67173
        Layer Name:             Receive/Accept
        Layer Run-Time ID:      44
Comprimi
host = CLIENT1   source = WinEventLog:Security   sourcetype = WinEventLog:Security
```

AI Support

Per ottenere una visione d'insieme della scansione individuata dal SIEM, ho utilizzato una query di ricerca avanzata sviluppata con il supporto dell'**AI**. A differenza della ricerca base effettuata prima (che stampava gli eventi di Security con sorgente l'IP di kali), questa query è stata progettata per essere molto più completa poiché non si limita a elencare i singoli eventi, ma li rielabora e raggruppa in una tabella riassuntiva.



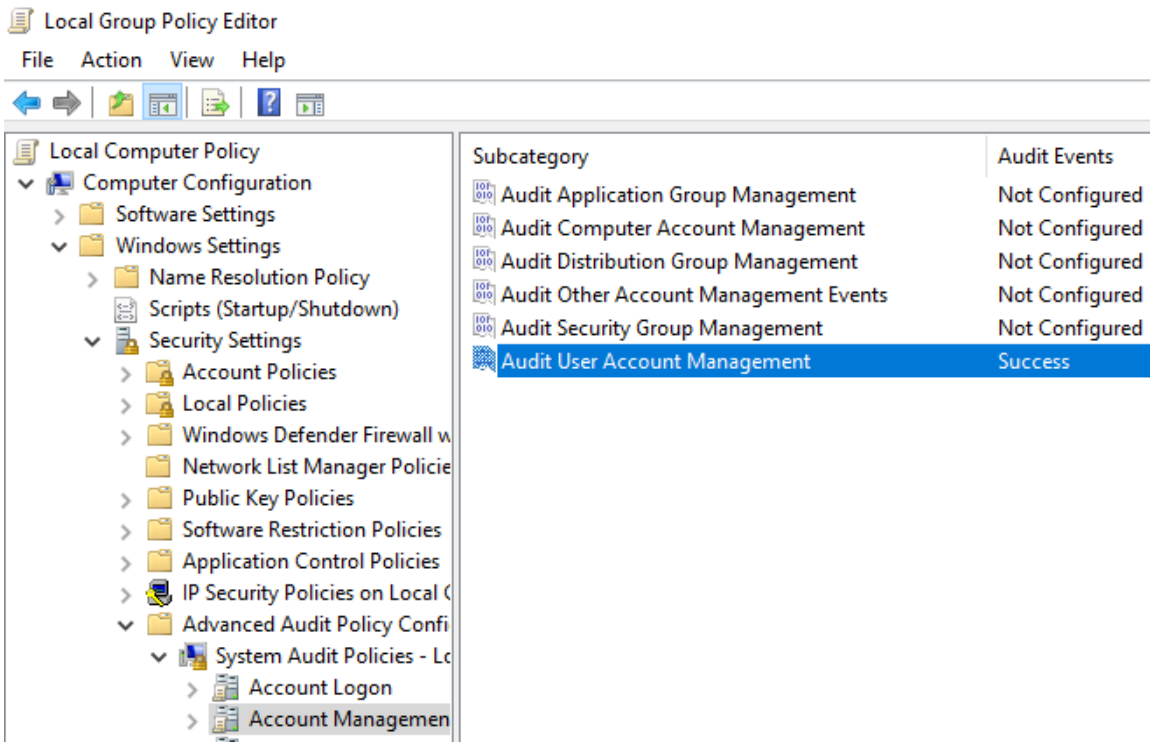
● **Conteggio Intelligente:** Invece di mostrarci migliaia di righe uguali, ci dice subito quanti tentativi totali sono stati fatti e quante porte diverse sono state colpite.

● **Traduzione automatica:** Traduce istantaneamente i codici numerici di Windows in parole semplici come "Consentito" o "Bloccato"

New GPO Domain Controller

Per rendere il monitoraggio delle identità nel dominio realmente efficace, si ha configurato una direttiva specifica all'interno dell'Advanced Audit Policy Configuration, navigando nel percorso dedicato all'Account Management sul Domain Controller. In questa sezione è stata abilitata la voce **Audit User Account Management** selezionando l'opzione Success, un passaggio che istruisce il sistema operativo a generare un log dettagliato ogni volta che un nuovo account viene creato da Active Directory. Grazie a questa procedura, il DC potrà inviare a Splunk l'**Event ID 4720**, la prova di qualsiasi nuova utenza comparsa nel dominio.
Per verificare che la policy sia stata inserita correttamente si ha digitato il seguente comando da promt.

```
C:\Users\Administrator>auditpol/get /subcategory:"User Account Management"
System audit policy
Category/Subcategory                      Setting
Account Management
  User Account Management                 Success
```



Creando la nuova utenza john.gomez da AD si è potuto constatare che:
L'evidenza digitale estratta dal SIEM documenta con precisione l'avvenuta creazione di un nuovo account all'interno del dominio, identificata formalmente dall'**EventCode 4720** e registrata nel log Security del Domain Controller WIN-IAUSSV51R0A.ciny.local.

index= EventCode=4720*

```
> 03/04/26      04/03/2026 07:41:05.781 PM
  19:41:05.781  LogName=Security
                EventCode=4720
                EventType=0
                ComputerName=WIN-IAUSSV51R0A.ciny.local
                SourceName=Microsoft Windows security auditing.
                Type=Information
                RecordNumber=29480
                Keywords=Audit Success
                TaskCategory=User Account Management
                OpCode=Info
                Message=A user account was created.

                Subject:
                        Security ID:            S-1-5-21-2478105729-4216169686-3928146933-500
                        Account Name:           Administrator
                        Account Domain:         CINY
                        Logon ID:               0x54360

                New Account:
                        Security ID:            S-1-5-21-2478105729-4216169686-3928146933-1111
                        Account Name:           john.gomez
                        Account Domain:         CINY

                Attributes:
                        SAM Account Name:       john.gomez
                        Display Name:           John Gomez
                        User Principal Name:    john.gomez@ciny.local
```

Conclusione

Il SIEM ha rilevato solo una frazione dei pacchetti inviati (circa il 5%) a causa dello Stealth Mode del client Windows, si verifica quando il firewall scarta pacchetti senza rispondere, facendo rilevare ad Nmap lo status "filtered". Mentre i tentativi sulle porte chiuse o aperte sono stati registrati fedelmente **(Event ID 5157 e 5156)**, le porte su cui è stato eseguito un **Packet Drop** dal firewall, non ha generato dei log, per evitare il sovraccarico di dati inutili nel SIEM, policy che potrebbe essere cambiata attivando la sottocategoria **Filtering Platform Packet Drop** (**Event ID 5152**).
La creazione di un nuovo user da DC ha generato, come ci si aspettava, un log di "AD Monitoring" con **Event ID 4720**.